

PRACTICAL CYBERSECURITY, PRIVACY & COMPLIANCE SERIES

PCI DSS v4.0.1

Practical Payment Security, Compliance Verification, and Open-Source Tools

A working manual for managers, junior analysts, students, career changers, merchants, and service providers

Alberto (Al) Leiva

First Edition • July 2026

Inside: Current PCI DSS v4.0.1 • all 12 requirements • scoping • SAQs and ROC • e-commerce • evidence • tools • labs • career preparation

Publication and Use Notice

Author: Alberto (Al) Leiva

Edition: First Edition, July 2026

Purpose: Free, practical education for managers, students, career changers, junior analysts, merchants, service providers, and cybersecurity practitioners.

Educational and legal notice

This manual provides general education. It is not legal advice, a PCI Security Standards Council publication, a Report on Compliance, an Attestation of Compliance, a Self-Assessment Questionnaire, or a guarantee of compliance or security. Only the official standard and applicable validation documents govern an assessment. Payment brands, acquirers, customers, regulators, contracts, and laws may impose additional requirements.

Ethical and authorized use

Use technical tools only on systems, networks, applications, cloud accounts, payment pages, and data that you own or are specifically authorized in writing to assess. Use synthetic account data in laboratories. Never use real PAN, sensitive authentication data, customer information, credentials, or production payment systems in a public demonstration or portfolio.

Preface

A welcoming introduction to payment security and evidence-based compliance.

PCI DSS protects payment account data through a baseline of technical and operational requirements. The difficult part is not memorizing twelve headings. It is about understanding where account data flows, defining the true cardholder data environment, controlling every system that can affect its security, applying safeguards consistently, and maintaining evidence to support each conclusion.

PCI DSS v4.0.1 is the current version supported by PCI SSC. It was published in June 2024 as a limited revision to v4.0. It added no requirements and removed none. PCI DSS v4.0 retired on December 31, 2024. The future-dated v4.x requirements became effective on March 31, 2025, and are now part of assessments.

This manual is methodology-first. A vulnerability scanner does not replace an Approved Scanning Vendor scan. A policy does not prove a control operates. A service-provider agreement does not remove the merchant's responsibility to understand shared duties. Managers own scope, resources, risk, and remediation; analysts make those decisions more reliable through complete evidence and clear testing.

How to Use This Manual

Managers should begin with Chapters 1–5 and 18–20.

Junior analysts should study the twelve requirement chapters, testing methods, tools, lab, and interview chapter.

Technical teams should connect every finding to account-data flow, CDE scope, requirement, owner, evidence, correction, and retest.

Merchants and service providers should confirm validation instructions with their acquirer, payment brands, customers, assessor, and other compliance-accepting entities.

True Word contents: The chapter guide below will contain verified page numbers for this edition. The document also contains a native Word TOC field. After editing, right-click it and select Update Field, then Update entire table.

Table of Contents

Publication and Use Notice	2
Educational and legal notice	2
Ethical and authorized use	2
Preface	3
How to Use This Manual	4
Table of Contents	4
1. PCI DSS v4.0.1 Foundations	8
1.1 Current status	8
1.2 Who and what it applies to	8
1.3 The six control goals	8
2. Account Data and Protection Rules	10
2.1 Protection methods are different	10
3. Scope, CDE, and Segmentation	12
3.1 Scope discovery	12
3.2 Scope validation	13
4. Validation, SAQs, ROC, AOC, and Roles	14
5. Defined, Customized, Compensating, and Risk Approaches	15
6. Requirement 1 — Network Security Controls	16
7. Requirement 2 — Secure Configurations	17
8. Requirement 3 — Stored Account Data	18

9. Requirement 4 — Transmission Cryptography	19
10. Requirement 5 — Malicious Software	20
11. Requirement 6 — Secure Systems and Software	21
12. Requirement 7 — Business Need to Know	23
13. Requirement 8 — Identity and Authentication	24
14. Requirement 9 — Physical Access	25
15. Requirement 10 — Logging and Monitoring	26
16. Requirement 11 — Security Testing	27
17. Requirement 12 — Policies and Programs	28
18. Evidence, Assessment, and Control Testing	30
18.1 Practical tests	30
19. Open-Source Tools for PCI DSS Work	32
19.1 Tool validation	32
19.2 CISO Assistant	32
Quick start	32
Evidence and limitation	33
19.3 Wazuh	33
Quick start	33
Evidence and limitation	33
19.4 osquery	33
Quick start	33
Evidence and limitation	33
19.5 OpenSCAP	33
Quick start	33
Evidence and limitation	34
19.6 Greenbone Community Edition	34
Quick start	34
Evidence and limitation	34
19.7 Nmap	34
Quick start	34
Evidence and limitation	34
19.8 Trivy	34
Quick start	34
Evidence and limitation	35

19.9 OWASP ZAP	35
Quick start	35
Evidence and limitation	35
19.10 ModSecurity + OWASP CRS.....	35
Quick start	35
Evidence and limitation	35
19.11 Suricata	35
Quick start	35
Evidence and limitation	36
19.12 Keycloak	36
Quick start	36
Evidence and limitation	36
19.13 DefectDojo.....	36
Quick start	36
Evidence and limitation	36
19.14 AIDE	36
Quick start	36
Evidence and limitation	36
19.15 Open Policy Agent	37
Quick start	37
Evidence and limitation	37
20. Manager's PCI DSS Playbook.....	38
20.1 Monthly questions	38
20.2 Dashboard	38
21. From Beginner to Junior PCI Analyst.....	39
21.1 Typical junior work.....	39
22. Fictional Laboratory and Portfolio	40
Project 1 — Scope	40
Project 2 — Requirements.....	40
Project 3 — Data.....	40
Project 4 — Access	40
Project 5 — Vulnerabilities	40
Project 6 — E-commerce	40
Project 7 — Incident.....	40

Project 8 — Management report	40
23. Thirty-Day Learning Plan.....	41
24. Interview Preparation	42
What is the current PCI DSS version?	42
What is the CDE?	42
What is PAN?	42
Can sensitive authentication data be stored if encrypted?	42
What is segmentation?	42
Defined versus customized approach?	42
Does an open-source scan replace ASV scanning?	42
How do you verify a requirement?	42
Who determines a merchant’s validation level?	42
What changed for e-commerce?	43
25. Templates, Glossary, and Index.....	44
25.1 Scope record	44
25.2 Requirement evidence record	44
25.3 Glossary	44
25.4 Subject index	45
26. Official References and Further Study.....	46

1. PCI DSS v4.0.1 Foundations

The current standard, applicability, goals, and important limitations.



PCI DSS combines technical, physical, operational, and governance requirements

Figure 1. The twelve PCI DSS requirements

1.1 Current status

- PCI DSS v4.0.1 was published June 11, 2024, as a limited revision.
- The revision clarified and corrected v4.0; it did not add or delete requirements.
- PCI DSS v4.0 retired December 31, 2024.
- The 51 future-dated requirements became effective March 31, 2025.
- As of this manual's July 2026 publication, PCI SSC is gathering stakeholder feedback on v4.0.1; a request for comments is not a new final standard.

1.2 Who and what it applies to

PCI DSS applies to entities that store, process, or transmit cardholder data or sensitive authentication data, and to entities whose systems could affect the security of the cardholder data environment. Merchants, processors, acquirers, issuers, and service providers may have different validation and reporting duties.

1.3 The six control goals

Goal	Requirements
Build and maintain a secure network and systems	1–2

Goal	Requirements
Protect account data	3–4
Maintain a vulnerability-management program	5–6
Implement strong access-control measures	7–9
Regularly monitor and test networks	10–11
Maintain an information-security policy	12

2. Account Data and Protection Rules

The difference between cardholder data, PAN, and sensitive authentication data.



PAN determines PCI DSS applicability when stored, processed, or transmitted with other account data

SAD must not be stored after authorization—even when encrypted—except where PCI DSS expressly permits issuer use

Figure 2. Account-data categories

Data	Type	Key rule
Primary Account Number (PAN)	Cardholder data	Determines PCI DSS applicability when stored, processed, or transmitted
Cardholder name	Cardholder data	Protected with PAN
Expiration date	Cardholder data	Protected with PAN
Service code	Cardholder data	Protected with PAN
Full track data	Sensitive authentication data	Do not store after authorization except expressly permitted issuer use
Card verification code/value	Sensitive authentication data	Do not store after authorization
PIN/PIN block	Sensitive authentication data	Do not store after authorization except expressly permitted issuer use

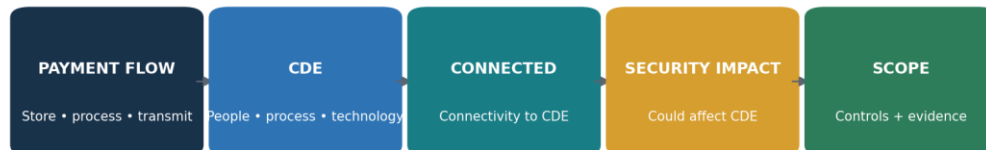
2.1 Protection methods are different

- Masking limits how much PAN is displayed.
- Truncation permanently removes a segment of PAN under defined formats.
- Encryption makes data unreadable without protected cryptographic keys.
- Hashing may render PAN unreadable when implemented with appropriate keyed cryptographic hashing and controls.
- Tokenization replaces PAN with a value, but token systems and detokenization paths may remain in scope.
- Redaction removes information from a copy or view; confirm that source data and hidden metadata are also controlled.

Never use real data in training: Use payment-processor test numbers or invented values that cannot be mistaken for actual accounts. Never retain real SAD after authorization.

3. Scope, CDE, and Segmentation

How to find every person, process, technology, and dependency that belongs in scope.

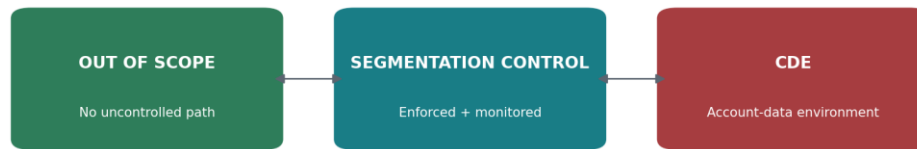


Scope begins with account-data flows and includes systems that connect to or can affect CDE security

Figure 3. PCI DSS scoping flow

3.1 Scope discovery

1. Identify all payment channels: e-commerce, point of sale, mail/telephone order, recurring billing, call center, mobile, kiosks, and outsourced services.
2. Trace account data from collection through authorization, settlement, storage, reporting, support, backups, logs, disposal, and third parties.
3. Identify CDE systems, people, processes, facilities, cloud services, applications, databases, network devices, security services, and administrative paths.
4. Identify connected-to systems and systems that can affect CDE security, including identity, DNS, time, logging, deployment, backup, virtualization, monitoring, and management platforms.
5. Identify segmentation controls and all paths that could bypass them.
6. Confirm third-party responsibilities, evidence, and locations.
7. Document exclusions, assumptions, diagrams, inventories, and validation results.



Segmentation reduces scope only when design and operating effectiveness are documented and tested

Figure 4. Segmentation and scope reduction

3.2 Scope validation

Validate scope at least annually and after significant change. Service providers perform the documented scope confirmation at least once every six months and after significant change. Testing should attempt to find unknown data stores, alternate paths, unmanaged assets, shared services, cloud dependencies, wireless connections, and administrative access.

4. Validation, SAQs, ROC, AOC, and Roles

Choosing the correct reporting path and understanding who accepts it.

Artifact or role	Purpose	Important limitation
SAQ A	Eligible fully outsourced card-not-present merchant environments	Eligibility is strict; the merchant still manages applicable website, service-provider, and policy duties
SAQ A-EP	Eligible e-commerce merchants with a website that can affect payment security	More requirements apply because the merchant page can affect the transaction
SAQ B / B-IP	Eligible imprint or specific standalone terminal environments	Not for e-commerce; eligibility must be exact
SAQ C / C-VT	Eligible payment application or isolated virtual-terminal environments	Environment and storage restrictions apply
SAQ P2PE	Eligible merchants using a listed PCI P2PE solution	Only validated solution use and eligibility qualify
SAQ D Merchant	Merchants not eligible for a shorter SAQ or directed to use it	Broad assessment of applicable requirements
SAQ D Service Provider	Service providers permitted to self-assess where accepted	Service-provider requirements and customer responsibilities apply
ROC	Detailed assessment report, usually completed by a QSA or ISA where required	Required based on compliance program, validation level, or request
AOC	Attestation summarizing assessment and compliance status	Must correspond to the correct SAQ or ROC and scope
ASV	PCI SSC Approved Scanning Vendor for required external vulnerability scans	Open-source scanning does not replace a required passing ASV scan
QSA / ISA	Qualified assessor or trained internal assessor roles	Use current qualifications and accepting-entity instructions

Who decides validation: Payment brands and acquirers establish merchant validation levels and reporting expectations. Customers and contracts may establish service-provider expectations. Confirm the required method before beginning.

5. Defined, Customized, Compensating, and Risk Approaches

Understanding flexibility without weakening the requirement objective.



Figure 5. Defined and customized approaches

Method	When used	Documentation focus
Defined approach	Entity implements the stated requirement	Requirement evidence and official testing procedures
Customized approach	Entity designs a different control that meets the customized objective	Control matrix, risk analysis, design, dependencies, testing, operating evidence, assessor validation
Compensating control	A legitimate technical or business constraint prevents the stated requirement	Constraint, objective, additional risk, compensating control, maintenance, validation, annual review
Targeted risk analysis — frequency	A requirement allows the entity to define how often an activity occurs	Assets, threats, likelihood, impact, rationale, frequency, owner, approval, annual review
Targeted risk analysis — customized	Supports customized-control design and validation	Threats, assumptions, control objective, design, residual risk, evidence, testing

The customized approach is not supported in every SAQ or requirement context.

A compensating control is not a shortcut for cost or convenience.

Targeted risk analysis does not remove a requirement; it supports a permitted decision.

Confirm acceptance and assessor expectations before committing to an approach.

6. Requirement 1 — Network Security Controls

Install and Maintain Network Security Controls

Requirement purpose: Install and Maintain Network Security Controls

Group	Plain meaning	Verification focus	Example evidence
1.1	Define, assign, and document the processes and roles used to meet Requirement 1.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	network diagrams, data flows, rule sets, approvals, six-month reviews, configuration exports
1.2	Configure network security controls with approved rules, standards, diagrams, reviews, and change control.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	network diagrams, data flows, rule sets, approvals, six-month reviews, configuration exports
1.3	Restrict inbound and outbound traffic to the cardholder data environment to what is necessary.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	network diagrams, data flows, rule sets, approvals, six-month reviews, configuration exports
1.4	Control connections between trusted and untrusted networks, including anti-spoofing and disclosure protections.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	network diagrams, data flows, rule sets, approvals, six-month reviews, configuration exports
1.5	Protect computing devices that connect to both untrusted networks and the CDE.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	network diagrams, data flows, rule sets, approvals, six-month reviews, configuration exports

Assessment note: Use the official PCI DSS v4.0.1 text and applicable reporting template for exact requirements, applicability notes, testing procedures, response options, and documentation. This manual explains; it does not replace the standard.

7. Requirement 2 — Secure Configurations

Apply Secure Configurations to All System Components

Requirement purpose: Apply Secure Configurations to All System Components

Group	Plain meaning	Verification focus	Example evidence
2.1	Define, assign, and document secure-configuration processes and roles.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	configuration standards, inventories, hardening scans, default-account and service reviews
2.2	Develop and apply configuration standards; remove defaults, unnecessary services, and insecure settings.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	configuration standards, inventories, hardening scans, default-account and service reviews
2.3	Secure wireless environments with changed defaults, strong cryptography, and managed settings.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	configuration standards, inventories, hardening scans, default-account and service reviews

Assessment note: Use the official PCI DSS v4.0.1 text and applicable reporting template for exact requirements, applicability notes, testing procedures, response options, and documentation. This manual explains; it does not replace the standard.

8. Requirement 3 — Stored Account Data

Protect Stored Account Data

Requirement purpose: Protect Stored Account Data

Group	Plain meaning	Verification focus	Example evidence
3.1	Define, assign, and document stored-account-data protection processes and roles.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	data inventory, retention schedule, discovery results, encryption and key-management records
3.2	Minimize account-data storage through retention, secure deletion, and data-location discovery.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	data inventory, retention schedule, discovery results, encryption and key-management records
3.3	Never retain sensitive authentication data after authorization, even when encrypted, except permitted issuer cases.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	data inventory, retention schedule, discovery results, encryption and key-management records
3.4	Limit displays and remote copying or relocation of full PAN to people with a documented need.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	data inventory, retention schedule, discovery results, encryption and key-management records
3.5	Render stored PAN unreadable using approved methods and protect any related mechanisms.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	data inventory, retention schedule, discovery results, encryption and key-management records
3.6	Protect cryptographic keys used to secure stored account data.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	data inventory, retention schedule, discovery results, encryption and key-management records
3.7	Operate complete key-management life-cycle processes.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	data inventory, retention schedule, discovery results, encryption and key-management records

Assessment note: Use the official PCI DSS v4.0.1 text and applicable reporting template for exact requirements, applicability notes, testing procedures, response options, and documentation. This manual explains; it does not replace the standard.

Critical prohibition: Sensitive authentication data must not be stored after authorization, even when encrypted, except where PCI DSS expressly permits issuer or issuing-support use.

9. Requirement 4 — Transmission Cryptography

Protect Cardholder Data with Strong Cryptography During Transmission Over Open, Public Networks

Requirement purpose: Protect Cardholder Data with Strong Cryptography During Transmission Over Open, Public Networks

Group	Plain meaning	Verification focus	Example evidence
4.1	Define, assign, and document transmission-protection processes and roles.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	data flows, protocol and certificate configuration, transmission tests, certificate inventory
4.2	Use strong cryptography and trusted keys or certificates whenever PAN crosses open, public networks.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	data flows, protocol and certificate configuration, transmission tests, certificate inventory

Assessment note: Use the official PCI DSS v4.0.1 text and applicable reporting template for exact requirements, applicability notes, testing procedures, response options, and documentation. This manual explains; it does not replace the standard.

10. Requirement 5 — Malicious Software

Protect All Systems and Networks from Malicious Software

Requirement purpose: Protect All Systems and Networks from Malicious Software

Group	Plain meaning	Verification focus	Example evidence
5.1	Define, assign, and document anti-malware processes and roles.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	malware-risk evaluations, agent coverage, policies, alerts, updates, phishing controls
5.2	Prevent, detect, and remove malware on systems commonly affected or periodically evaluated as not at risk.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	malware-risk evaluations, agent coverage, policies, alerts, updates, phishing controls
5.3	Keep anti-malware mechanisms active, current, protected, logged, monitored, and limited to authorized disablement.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	malware-risk evaluations, agent coverage, policies, alerts, updates, phishing controls
5.4	Use automated mechanisms and training processes to protect personnel from phishing attacks.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	malware-risk evaluations, agent coverage, policies, alerts, updates, phishing controls

Assessment note: Use the official PCI DSS v4.0.1 text and applicable reporting template for exact requirements, applicability notes, testing procedures, response options, and documentation. This manual explains; it does not replace the standard.

11. Requirement 6 — Secure Systems and Software

Develop and Maintain Secure Systems and Software

Requirement purpose: Develop and Maintain Secure Systems and Software

Group	Plain meaning	Verification focus	Example evidence
6.1	Define, assign, and document secure-system and software processes and roles.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	software inventory, SDLC records, code review, scan results, patches, scripts, change tickets
6.2	Develop bespoke and custom software securely, with trained staff, reviews, testing, and flaw prevention.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	software inventory, SDLC records, code review, scan results, patches, scripts, change tickets
6.3	Identify, prioritize, and address vulnerabilities; maintain software inventories and apply security patches.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	software inventory, SDLC records, code review, scan results, patches, scripts, change tickets
6.4	Protect public-facing web applications and manage all payment-page scripts.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	software inventory, SDLC records, code review, scan results, patches, scripts, change tickets
6.5	Manage changes to systems, software, and the production environment securely.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	software inventory, SDLC records, code review, scan results, patches, scripts, change tickets

Assessment note: Use the official PCI DSS v4.0.1 text and applicable reporting template for exact requirements, applicability notes, testing procedures, response options, and documentation. This manual explains; it does not replace the standard.



Requirements 6.4.3 and 11.6.1 reduce e-skimming risk by governing and monitoring payment pages

Figure 6. E-commerce payment-page protection

Requirements 6.4.3 and 11.6.1 are now effective. Maintain an inventory and business or technical justification for payment-page scripts, authorize them, assure their integrity, and deploy change/tamper

detection for relevant pages and HTTP headers at least as frequently as required or supported by the permitted targeted risk analysis.

12. Requirement 7 — Business Need to Know

Restrict Access to System Components and Cardholder Data by Business Need to Know

Requirement purpose: Restrict Access to System Components and Cardholder Data by Business Need to Know

Group	Plain meaning	Verification focus	Example evidence
7.1	Define, assign, and document access-control processes and roles.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	role matrix, approvals, access exports, reviews, deny tests, removal evidence
7.2	Define, approve, assign, enforce, and review access according to job need, least privilege, and deny-by-default.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	role matrix, approvals, access exports, reviews, deny tests, removal evidence
7.3	Manage application and system accounts and their access according to business need and risk.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	role matrix, approvals, access exports, reviews, deny tests, removal evidence

Assessment note: Use the official PCI DSS v4.0.1 text and applicable reporting template for exact requirements, applicability notes, testing procedures, response options, and documentation. This manual explains; it does not replace the standard.

13. Requirement 8 — Identity and Authentication

Identify Users and Authenticate Access to System Components

Requirement purpose: Identify Users and Authenticate Access to System Components

Group	Plain meaning	Verification focus	Example evidence
8.1	Define, assign, and document identity and authentication processes and roles.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	identity population, account records, MFA and password settings, authentication logs and tests
8.2	Use unique identities and manage the complete user-account life cycle.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	identity population, account records, MFA and password settings, authentication logs and tests
8.3	Use strong authentication factors, secure resets, lockouts, password/passphrase rules, and protected credentials.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	identity population, account records, MFA and password settings, authentication logs and tests
8.4	Implement multi-factor authentication for CDE access and applicable remote access.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	identity population, account records, MFA and password settings, authentication logs and tests
8.5	Configure MFA systems to resist bypass and misuse.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	identity population, account records, MFA and password settings, authentication logs and tests
8.6	Strictly manage application, system, and shared account use and authentication factors.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	identity population, account records, MFA and password settings, authentication logs and tests

Assessment note: Use the official PCI DSS v4.0.1 text and applicable reporting template for exact requirements, applicability notes, testing procedures, response options, and documentation. This manual explains; it does not replace the standard.

Authentication reminder: Requirement 8 contains detailed rules for unique IDs, inactive and terminated accounts, strong passwords/passphrases, MFA, service accounts, authentication factors, and secure reset. Verify exact applicability in the official standard.

14. Requirement 9 — Physical Access

Restrict Physical Access to Cardholder Data

Requirement purpose: Restrict Physical Access to Cardholder Data

Group	Plain meaning	Verification focus	Example evidence
9.1	Define, assign, and document physical-security processes and roles.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	badge and visitor logs, camera records, media inventory, destruction proof, POI inspections
9.2	Use appropriate entry controls and monitoring for facilities and sensitive areas.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	badge and visitor logs, camera records, media inventory, destruction proof, POI inspections
9.3	Authorize, identify, monitor, and promptly revoke personnel and visitor access.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	badge and visitor logs, camera records, media inventory, destruction proof, POI inspections
9.4	Classify, store, move, copy, destroy, and track media containing cardholder data securely.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	badge and visitor logs, camera records, media inventory, destruction proof, POI inspections
9.5	Protect point-of-interaction devices from tampering and substitution.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	badge and visitor logs, camera records, media inventory, destruction proof, POI inspections

Assessment note: Use the official PCI DSS v4.0.1 text and applicable reporting template for exact requirements, applicability notes, testing procedures, response options, and documentation. This manual explains; it does not replace the standard.

15. Requirement 10 — Logging and Monitoring

Log and Monitor All Access to System Components and Cardholder Data

Requirement purpose: Log and Monitor All Access to System Components and Cardholder Data

Group	Plain meaning	Verification focus	Example evidence
10.1	Define, assign, and document logging and monitoring processes and roles.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	Log-source inventory, audit records, review tickets, retention settings, time configuration, failure alerts
10.2	Generate audit logs that support anomaly detection, accountability, investigation, and forensics.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	Log-source inventory, audit records, review tickets, retention settings, time configuration, failure alerts
10.3	Protect audit logs from unauthorized access, change, and deletion.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	Log-source inventory, audit records, review tickets, retention settings, time configuration, failure alerts
10.4	Review logs and security events at required or risk-determined frequencies, using automation where required.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	Log-source inventory, audit records, review tickets, retention settings, time configuration, failure alerts
10.5	Retain audit-log history, with at least the required recent period immediately available.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	Log-source inventory, audit records, review tickets, retention settings, time configuration, failure alerts
10.6	Synchronize system time using approved, protected time sources and settings.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	Log-source inventory, audit records, review tickets, retention settings, time configuration, failure alerts
10.7	Detect, report, respond to, and document failures of critical security control systems.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	Log-source inventory, audit records, review tickets, retention settings, time configuration, failure alerts

Assessment note: Use the official PCI DSS v4.0.1 text and applicable reporting template for exact requirements, applicability notes, testing procedures, response options, and documentation. This manual explains; it does not replace the standard.

16. Requirement 11 — Security Testing

Test Security Systems and Processes Regularly

Requirement purpose: Test Security Systems and Processes Regularly

Group	Plain meaning	Verification focus	Example evidence
11.1	Define, assign, and document security-testing processes and roles.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	wireless results, scan reports, ASV evidence, penetration tests, IDS/FIM alerts, page-change monitoring
11.2	Detect and manage authorized and unauthorized wireless access points.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	wireless results, scan reports, ASV evidence, penetration tests, IDS/FIM alerts, page-change monitoring
11.3	Perform, correct, and repeat required internal and external vulnerability scans, including ASV scans where applicable.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	wireless results, scan reports, ASV evidence, penetration tests, IDS/FIM alerts, page-change monitoring
11.4	Perform internal and external penetration testing, segmentation testing, correction, and retesting.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	wireless results, scan reports, ASV evidence, penetration tests, IDS/FIM alerts, page-change monitoring
11.5	Detect and respond to network intrusions and unauthorized changes to critical files.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	wireless results, scan reports, ASV evidence, penetration tests, IDS/FIM alerts, page-change monitoring
11.6	Detect and respond to unauthorized changes in payment pages and security-impacting HTTP headers.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	wireless results, scan reports, ASV evidence, penetration tests, IDS/FIM alerts, page-change monitoring

Assessment note: Use the official PCI DSS v4.0.1 text and applicable reporting template for exact requirements, applicability notes, testing procedures, response options, and documentation. This manual explains; it does not replace the standard.

Do not substitute tools: Community vulnerability scanners can support internal work but do not replace the requirement to pass external ASV scans. Automated web scanners do not replace required penetration testing or qualified manual assessment.

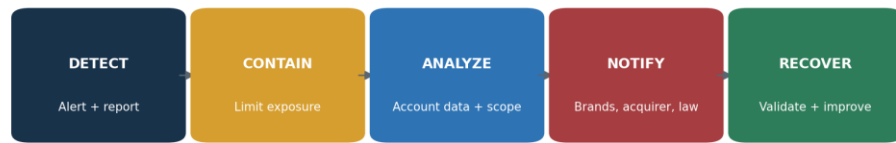
17. Requirement 12 — Policies and Programs

Support Information Security with Organizational Policies and Programs

Requirement purpose: Support Information Security with Organizational Policies and Programs

Group	Plain meaning	Verification focus	Example evidence
12.1	Establish, publish, maintain, acknowledge, and review the information-security policy and responsibilities.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	policies, risk analyses, scope validation, training, personnel checks, TPSP files, incident exercises
12.2	Maintain acceptable-use policies for end-user technologies.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	policies, risk analyses, scope validation, training, personnel checks, TPSP files, incident exercises
12.3	Identify and manage PCI DSS risks through targeted analyses and annual reviews of cryptography and technology.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	policies, risk analyses, scope validation, training, personnel checks, TPSP files, incident exercises
12.4	Manage, monitor, and report PCI DSS compliance responsibilities, with added service-provider oversight.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	policies, risk analyses, scope validation, training, personnel checks, TPSP files, incident exercises
12.5	Document, confirm, and validate the PCI DSS scope at least annually and after significant changes; service providers do so every 6 months.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	policies, risk analyses, scope validation, training, personnel checks, TPSP files, incident exercises
12.6	Operate a continuing, role-aware security-awareness program with phishing and acceptable-use content.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	policies, risk analyses, scope validation, training, personnel checks, TPSP files, incident exercises
12.7	Screen prospective personnel who will have access to the CDE, subject to law and role risk.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	policies, risk analyses, scope validation, training, personnel checks, TPSP files, incident exercises
12.8	Maintain and govern third-party service-provider relationships, responsibility matrices, agreements, and monitoring.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	policies, risk analyses, scope validation, training, personnel checks, TPSP files, incident exercises
12.9	Require service providers to acknowledge in writing their responsibility for account data security and to support customers.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	policies, risk analyses, scope validation, training, personnel checks, TPSP files, incident exercises
12.10	Maintain, test, review, and improve an incident-response plan that addresses payment account data.	Confirm scope, ownership, design, implementation, operating evidence, exceptions, correction, and retest.	policies, risk analyses, scope validation, training, personnel checks, TPSP files, incident exercises

Assessment note: Use the official PCI DSS v4.0.1 text and applicable reporting template for exact requirements, applicability notes, testing procedures, response options, and documentation. This manual explains; it does not replace the standard.

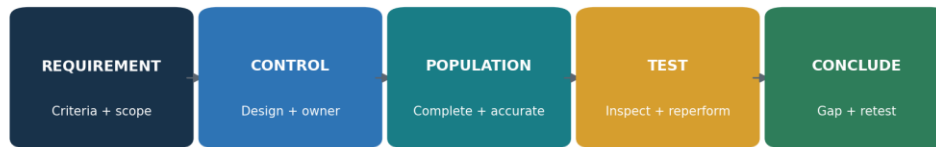


Payment incidents require prepared contacts, evidence preservation, contractual escalation, and tested recovery

Figure 8. Payment incident response workflow

18. Evidence, Assessment, and Control Testing

How to verify that PCI DSS requirements are implemented and operating.



A policy or tool output is not enough: assess design, implementation, operation, exceptions, and correction

Figure 7. Requirement-to-evidence chain

- Define the exact requirement, applicability, scope, control, owner, systems, locations, period, frequency, and expected evidence.
- Evaluate design: would the control reasonably meet the defined or customized objective?
- Obtain the complete population and validate completeness and accuracy against independent sources.
- Select a risk-based sample covering relevant dates, assets, owners, failures, exceptions, changes, and service providers.
- Inspect configurations, records, observations, interviews, and system data; reperform where practical.
- Document exceptions with criteria, facts, duration, affected account data and systems, cause, impact, and existing protection.
- Assign remediation, interim protection, owner, resources, due date, and escalation.
- Retest the correction across the affected population and state the conclusion and limitations.

18.1 Practical tests

Area	Population and sample	Test	Evidence
Scope	All payment channels, systems, data stores, suppliers, and segmentation paths	Reconcile diagrams and inventories to network, identity, cloud, discovery, procurement, and support sources	Data flows, inventory, discovery results, segmentation tests, signed scope
Network rules	All CDE-connected rules; sample changes, temporary rules, and reviews	Trace business need, approval, implementation, review, expiry, and traffic behavior	Rule export, ticket, owner, review, test and removal
Stored data	All known and discovered repositories	Test retention, deletion, PAN rendering, key protection, SAD prohibition, and remote-copy controls	Discovery, samples, configuration, deletion and key records
Access	All workforce, privileged, service, application, and third-party accounts	Test need, approval, MFA, authentication, review, change, inactivity, and termination	Populations, settings, logs, approvals, reviews and tickets
Vulnerabilities	All in-scope assets and findings	Validate coverage, authenticated scanning, risk ranking, patching, ASV status, exception, and rescan	Inventory, scan settings, reports, tickets, passing ASV evidence

Area	Population and sample	Test	Evidence
Logs	All required sources, reviews, alerts, retention, and control failures	Test fields, protection, time, review frequency, automation, investigation, and failure response	Source list, configurations, alerts, tickets, retention and time proof
Payment pages	All scripts, pages, headers, changes, and alerts	Test authorization, justification, integrity, inventory, monitoring, frequency, alert and response	Script inventory, approvals, integrity method, alert, ticket and retest
Third parties	Complete TPSP population; sample critical, new, changed, and terminated providers	Test agreement, responsibility matrix, status, monitoring, incident duties, scope effect, and exit	Inventory, contracts, AOCs, matrix, reviews, findings and removal proof

19. Open-Source Tools for PCI DSS Work

Official links, safe quick starts, evidence, and limitations.

Tool	Purpose	Possible PCI DSS support
CISO Assistant	GRC, requirements, evidence, risks	12, all
Wazuh	Endpoint security, malware, logs, integrity	5, 10, 11
osquery	Asset, software, account, and configuration queries	2, 5, 8, 10
OpenSCAP	Linux secure-configuration assessment	2, 6
Greenbone Community Edition	Internal vulnerability assessment	6, 11
Nmap	Authorized service and segmentation discovery	1, 2, 11
Trivy	Code, image, dependency, secret, and configuration scanning	6
OWASP ZAP	Authorized web-application assessment	6, 11
ModSecurity + OWASP CRS	Web application firewall controls	6.4.2
Suricata	Network intrusion detection	11.5
Keycloak	Identity, access, MFA, and authentication	7, 8
DefectDojo	Finding intake, remediation, and retest	6, 11, 12
AIDE	File-integrity monitoring	11.5.2
Open Policy Agent	Policy as code	2, 6, 7

Critical limitation: These tools can support evidence and security operations. They cannot make an entity PCI DSS compliant, replace a QSA/ISA judgment, replace required ASV scans, or replace qualified penetration testing.

19.1 Tool validation

- Approve purpose, scope, systems, data, ownership, hosting, access, and retention.
- Verify official source, version, dependencies, integrity, updates, and secure configuration.
- Create a known condition the tool should detect or block and a known allowed condition.
- Compare agent, asset, repository, target, identity, or log coverage with an independent population.
- Protect administrative credentials, reports, rules, logs, and backups.
- Define human review, escalation, correction, exception, and retest.
- Revalidate after changes, upgrades, integration changes, or failures.

19.2 CISO Assistant

GRC, requirements, evidence, risks. Possible PCI DSS support: 12, all.

Official documentation: [Open the official CISO Assistant guide](#)

Quick start

Create a fictional merchant, map five requirement groups, assign owners, attach sanitized evidence, and track a gap through retest.

Evidence and limitation

Retain authorization, purpose, complete target population, versions, configuration, raw result, reviewer, decision, corrective action, exception, and retest. Protect results containing PAN, credentials, architecture, identities, or vulnerabilities. Never place real account data in an unapproved tool.

19.3 Wazuh

Endpoint security, malware, logs, integrity. Possible PCI DSS support: 5, 10, 11.

Official documentation: [Open the official Wazuh guide](#)

Quick start

Connect an authorized lab endpoint, generate a harmless event, review the alert, and retain the event, rule, review, and ticket.

Evidence and limitation

Retain authorization, purpose, complete target population, versions, configuration, raw result, reviewer, decision, corrective action, exception, and retest. Protect results containing PAN, credentials, architecture, identities, or vulnerabilities. Never place real account data in an unapproved tool.

19.4 osquery

Asset, software, account, and configuration queries. Possible PCI DSS support: 2, 5, 8, 10.

Official documentation: [Open the official osquery guide](#)

Quick start

Query lab users, software, services, encryption, or processes; retain query, host population, time, output, and review.

Evidence and limitation

Retain authorization, purpose, complete target population, versions, configuration, raw result, reviewer, decision, corrective action, exception, and retest. Protect results containing PAN, credentials, architecture, identities, or vulnerabilities. Never place real account data in an unapproved tool.

19.5 OpenSCAP

Linux secure-configuration assessment. Possible PCI DSS support: 2, 6.

Official documentation: [Open the official OpenSCAP guide](#)

Quick start

Assess an approved Linux lab against a suitable profile, correct one approved setting, and compare reports.

Evidence and limitation

Retain authorization, purpose, complete target population, versions, configuration, raw result, reviewer, decision, corrective action, exception, and retest. Protect results containing PAN, credentials, architecture, identities, or vulnerabilities. Never place real account data in an unapproved tool.

19.6 Greenbone Community Edition

Internal vulnerability assessment. Possible PCI DSS support: 6, 11.

Official documentation: [Open the official Greenbone Community Edition guide](#)

Quick start

Scan only an approved lab target, validate a finding, correct it, rescan, and document coverage and limits.

Evidence and limitation

Retain authorization, purpose, complete target population, versions, configuration, raw result, reviewer, decision, corrective action, exception, and retest. Protect results containing PAN, credentials, architecture, identities, or vulnerabilities. Never place real account data in an unapproved tool.

19.7 Nmap

Authorized service and segmentation discovery. Possible PCI DSS support: 1, 2, 11.

Official documentation: [Open the official Nmap guide](#)

Quick start

Scan a small authorized lab range, compare observed services with the inventory, and record scope and approval.

Evidence and limitation

Retain authorization, purpose, complete target population, versions, configuration, raw result, reviewer, decision, corrective action, exception, and retest. Protect results containing PAN, credentials, architecture, identities, or vulnerabilities. Never place real account data in an unapproved tool.

19.8 Trivy

Code, image, dependency, secret, and configuration scanning. Possible PCI DSS support: 6.

Official documentation: [Open the official Trivy guide](#)

Quick start

Scan a pinned lab image or test repository, protect output, validate one finding, correct it, and scan again.

Evidence and limitation

Retain authorization, purpose, complete target population, versions, configuration, raw result, reviewer, decision, corrective action, exception, and retest. Protect results containing PAN, credentials, architecture, identities, or vulnerabilities. Never place real account data in an unapproved tool.

19.9 OWASP ZAP

Authorized web-application assessment. Possible PCI DSS support: 6, 11.

Official documentation: [Open the official OWASP ZAP guide](#)

Quick start

Proxy a local training application, start with passive analysis, validate a result, and retain scope and evidence.

Evidence and limitation

Retain authorization, purpose, complete target population, versions, configuration, raw result, reviewer, decision, corrective action, exception, and retest. Protect results containing PAN, credentials, architecture, identities, or vulnerabilities. Never place real account data in an unapproved tool.

19.10 ModSecurity + OWASP CRS

Web application firewall controls. Possible PCI DSS support: 6.4.2.

Official documentation: [Open the official ModSecurity + OWASP CRS guide](#)

Quick start

Deploy only in a lab, record rule version and mode, test a harmless request, tune a false positive, and preserve change approval.

Evidence and limitation

Retain authorization, purpose, complete target population, versions, configuration, raw result, reviewer, decision, corrective action, exception, and retest. Protect results containing PAN, credentials, architecture, identities, or vulnerabilities. Never place real account data in an unapproved tool.

19.11 Suricata

Network intrusion detection. Possible PCI DSS support: 11.5.

Official documentation: [Open the official Suricata guide](#)

Quick start

Monitor an isolated lab segment, trigger a harmless test alert, and document rule, traffic source, alert, review, and response.

Evidence and limitation

Retain authorization, purpose, complete target population, versions, configuration, raw result, reviewer, decision, corrective action, exception, and retest. Protect results containing PAN, credentials, architecture, identities, or vulnerabilities. Never place real account data in an unapproved tool.

19.12 Keycloak

Identity, access, MFA, and authentication. Possible PCI DSS support: 7, 8.

Official documentation: [Open the official Keycloak guide](#)

Quick start

Create a lab realm, roles, users, and MFA; test least privilege, failed access, review, and termination.

Evidence and limitation

Retain authorization, purpose, complete target population, versions, configuration, raw result, reviewer, decision, corrective action, exception, and retest. Protect results containing PAN, credentials, architecture, identities, or vulnerabilities. Never place real account data in an unapproved tool.

19.13 DefectDojo

Finding intake, remediation, and retest. Possible PCI DSS support: 6, 11, 12.

Official documentation: [Open the official DefectDojo guide](#)

Quick start

Import a lab scan, validate and assign one finding, record remediation, retest, and close with evidence.

Evidence and limitation

Retain authorization, purpose, complete target population, versions, configuration, raw result, reviewer, decision, corrective action, exception, and retest. Protect results containing PAN, credentials, architecture, identities, or vulnerabilities. Never place real account data in an unapproved tool.

19.14 AIDE

File-integrity monitoring. Possible PCI DSS support: 11.5.2.

Official documentation: [Open the official AIDE guide](#)

Quick start

Create a baseline on a disposable lab host, make an authorized file change, review the alert, restore, and document the process.

Evidence and limitation

Retain authorization, purpose, complete target population, versions, configuration, raw result, reviewer, decision, corrective action, exception, and retest. Protect results containing PAN, credentials, architecture, identities, or vulnerabilities. Never place real account data in an unapproved tool.

19.15 Open Policy Agent

Policy as code. Possible PCI DSS support: 2, 6, 7.

Official documentation: [Open the official Open Policy Agent guide](#)

Quick start

Create a lab policy that denies deployment without an owner, classification, an approved network, and a security scan status.

Evidence and limitation

Retain authorization, purpose, complete target population, versions, configuration, raw result, reviewer, decision, corrective action, exception, and retest. Protect results containing PAN, credentials, architecture, identities, or vulnerabilities. Never place real account data in an unapproved tool.

20. Manager's PCI DSS Playbook

Questions, dashboards, ownership, and decisions managers should control.

20.1 Monthly questions

Did payment channels, data flows, systems, suppliers, scripts, cloud services, or administrative paths change?

Is scope complete and validated, including connected-to and security-impacting systems?

Has any account data appeared where it was not expected?

Are high-risk findings, failed controls, ASV results, penetration tests, and remediation on schedule?

Are service-provider responsibilities and current compliance evidence understood?

Are payment-page scripts and change-detection alerts reviewed?

Are access, MFA, logging, malware, patching, backups, and incident controls operating consistently?

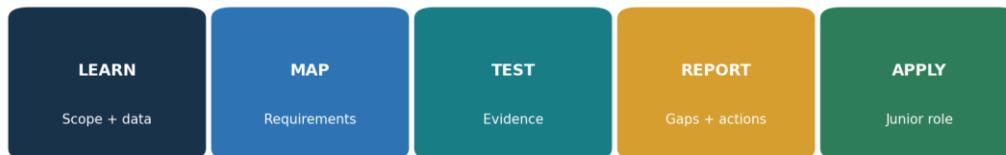
What limitations or unresolved exceptions must leadership and the accepting entity know?

20.2 Dashboard

Area	Manager question	Status
Scope	Are all channels, data, systems, paths, suppliers, and scripts current?	Green / Yellow / Red
Data	Is storage minimized and PAN/SAD treatment correct?	Green / Yellow / Red
Network/configuration	Are rules, hardening, reviews, and segmentation operating?	Green / Yellow / Red
Access	Are need, MFA, accounts, reviews, and termination controlled?	Green / Yellow / Red
Vulnerabilities	Are patches, scans, ASV results, penetration tests, and retests up to date?	Green / Yellow / Red
Monitoring	Are logs, alerts, integrity, IDS, control failures, and payment pages reviewed?	Green / Yellow / Red
Third parties	Are responsibilities, status, monitoring, incidents, and exits controlled?	Green / Yellow / Red
Response	Are payment incidents tested, escalated, preserved, communicated, and improved?	Green / Yellow / Red

21. From Beginner to Junior PCI Analyst

A safe and honest path into payment-security compliance work.



A strong portfolio uses synthetic data, honest scope, safe tools, reliable evidence, and clear writing

Figure 9. Junior PCI analyst pathway

Junior PCI Compliance Analyst
GRC Analyst — Payments
Security Controls Analyst
PCI Evidence Coordinator
Third-Party Risk Analyst
Vulnerability Management Analyst
Security Assurance Analyst
Payment Security Analyst

21.1 Typical junior work

- Maintain payment-channel, data-flow, system, supplier, account, script, and evidence inventories.
- Gather and organize evidence without altering source records.
- Review samples for network rules, configurations, access, MFA, patches, logs, training, and provider oversight.
- Track ASV scans, internal scans, penetration tests, findings, exceptions, remediation, and retests.
- Support scope validation, data discovery, responsibility matrices, and incident exercises.
- Write clear conclusions without claiming assessor authority.
- Protect account data and follow authorization boundaries.

22. Fictional Laboratory and Portfolio

A complete practice environment using synthetic data and authorized lab systems.

Harbor Light Market is a fictional merchant with a hosted payment page, two point-of-sale terminals, a call center, cloud collaboration, a managed service provider, and a fictional processor. All account numbers, people, systems, alerts, and suppliers are invented or approved test data.

Project 1 — Scope

Map channels, account data, CDE, connected systems, security-impacting systems, suppliers, and segmentation.

Project 2 — Requirements

Create a 12-requirement responsibility and evidence matrix.

Project 3 — Data

Run a synthetic data-discovery exercise and document retention, deletion, and PAN protection.

Project 4 — Access

Test fictional joiner, mover, leaver, privileged, service-account, and MFA evidence.

Project 5 — Vulnerabilities

Perform an authorized lab scan, validate, correct, rescan, and explain why ASV evidence is separate.

Project 6 — E-commerce

Inventory synthetic payment scripts, justify and authorize them, validate integrity, and test a harmless change alert.

Project 7 — Incident

Run a tabletop involving unexpected PAN and a changed payment script; preserve facts, escalate, contain, recover, and improve.

Project 8 — Management report

Prepare scope, status, top gaps, action plan, decisions, and limitations.

Portfolio ethics: Label every item as fictional training. Never publish real PAN, SAD, customer data, credentials, payment architecture, scan results, incidents, contracts, or assessor reports.

23. Thirty-Day Learning Plan

A realistic month of official reading, practical evidence, and interview preparation.

Week	Focus	Required output
Week 1	Foundations, account data, scope, segmentation, validation	Scope memo, data map, inventory, SAQ decision questions
Week 2	Requirements 1–6	Network/configuration evidence, data rules, patch and software-security test
Week 3	Requirements 7–12	Access test, logging review, scan file, provider matrix, incident tabletop
Week 4	Tools, portfolio, reporting, interview	Sanitized portfolio, dashboard, practiced answers

24. Interview Preparation

Short, accurate answers for junior analysts and managers.

What is the current PCI DSS version?

PCI DSS v4.0.1. It was published in June 2024 as a limited revision. PCI DSS v4.0 retired at the end of 2024, and future-dated v4.x requirements became effective March 31, 2025.

What is the CDE?

The people, processes, and technologies that store, process, or transmit cardholder data or sensitive authentication data, plus relevant systems that connect to or can affect its security.

What is PAN?

The primary account number. Its presence is central to PCI DSS applicability.

Can sensitive authentication data be stored if encrypted?

Not after authorization, except where PCI DSS expressly permits certain issuer or issuing-support use.

What is segmentation?

Controls that isolate the CDE. It reduces scope only when design and effectiveness are documented and tested.

Defined versus customized approach?

The defined approach follows the stated requirement. A customized approach uses another control design that meets the customized objective and requires extensive risk, design, evidence, and assessor validation.

Does an open-source scan replace ASV scanning?

No. Required external vulnerability scans must be performed through an Approved Scanning Vendor and meet program requirements.

How do you verify a requirement?

Define criteria and scope, evaluate design, obtain a complete population, test representative items, record exceptions, remediate, retest, and state limitations.

Who determines a merchant's validation level?

Payment brands and acquirers establish compliance programs and validation expectations; contracts and customers can add requirements.

What changed for e-commerce?

Requirements 6.4.3 and 11.6.1 require stronger governance of payment-page scripts and detection of unauthorized changes to relevant pages and headers.

Manager's 60-second answer: I begin with payment channels and account-data flows, define the true CDE and systems that can affect it, confirm the correct validation path, assign requirement ownership, and require complete operating evidence. We minimize data, control access and suppliers, protect payment pages, scan and test according to PCI rules, remediate and retest findings, and escalate incidents promptly. Tools support the work, but scope, evidence, assessor judgment, and management accountability determine whether conclusions are reliable.

25. Templates, Glossary, and Index

Reusable structures and plain-English definitions.

25.1 Scope record

- ✓ Payment channel, purpose, owner, locations, and transaction flow
- ✓ PAN, CHD, SAD, storage, processing, transmission, retention, and disposal
- ✓ CDE systems, connected-to systems, security-impacting systems, people, processes, and facilities
- ✓ Networks, cloud, identity, logging, time, backup, support, deployment, security tools, and administrative paths
- ✓ TPSPs, services, data, access, locations, subcontractors, responsibilities, and compliance evidence
- ✓ Segmentation design, enforcement points, monitoring, tests, bypass paths, and conclusion
- ✓ Changes, assumptions, exclusions, limitations, validation date, approver, and next review

25.2 Requirement evidence record

- ✓ Requirement and approach
- ✓ Applicability and rationale
- ✓ Control, owner, frequency, systems, and period
- ✓ Expected evidence and complete population
- ✓ Sample and procedure
- ✓ Results, exceptions, cause, risk, remediation, interim protection, and date
- ✓ Retest, conclusion, reviewer, approval, and limitation

25.3 Glossary

AOC. Attestation of Compliance.

ASV. A PCI SSC Approved Scanning Vendor.

Cardholder data. PAN plus related cardholder name, expiration date, or service code.

CDE. The cardholder data environment.

Compensating control. A documented alternative used when a legitimate constraint prevents meeting a defined requirement, while protecting the requirement objective.

Customized approach. An entity-designed control approach that meets a PCI DSS customized objective and requires additional documentation and validation.

PAN. Primary Account Number.

QSA. Qualified Security Assessor.

ROC. Report on Compliance.

SAD. Sensitive authentication data: full track data, verification codes/values, and PIN/PIN blocks.

SAQ. Self-Assessment Questionnaire.

Segmentation. Controls used to isolate the CDE and potentially reduce scope.

Targeted risk analysis. A PCI DSS v4.x analysis supporting specified frequency decisions or customized controls.

TPSP. Third-party service provider.

25.4 Subject index

Topic	Chapters	Topic	Chapters
Account data	2, 8–9	Open-source tools	19
ASV	4, 16, 18–19	PAN	2, 8
Authentication	13, 18–19	Penetration testing	16, 18
CDE	1–3, 18	SAQ	4
Compensating controls	5	Scope	3–4, 17–18, 25
Customized approach	5	Segmentation	3, 16, 18
E-commerce	11, 16, 18	Sensitive authentication data	2, 8
Evidence	18–20	Service providers	3–4, 17–18
Incident response	17, 22	Targeted risk analysis	5, 17
Junior analyst	21–24	Vulnerability scanning	11, 16, 18–19
Logging	15, 18–19		

26. Official References and Further Study

Current PCI SSC sources and official tool documentation used for verification.

[PCI SSC Document Library](#)

[PCI DSS v4.x Resource Hub](#)

[Just Published: PCI DSS v4.0.1](#)

[PCI DSS standards overview](#)

[Targeted Risk Analysis Guidance](#)

[Payment Page Security and Preventing E-Skimming](#)

[PCI SSC Qualified Assessors](#)

[PCI SSC Approved Scanning Vendors](#)

Final reminder: PCI SSC publications, FAQs, forms, guidance, assessor listings, payment-brand programs, acquirer instructions, contracts, technologies, and threats change. Confirm the official current standard and reporting path before a real assessment.